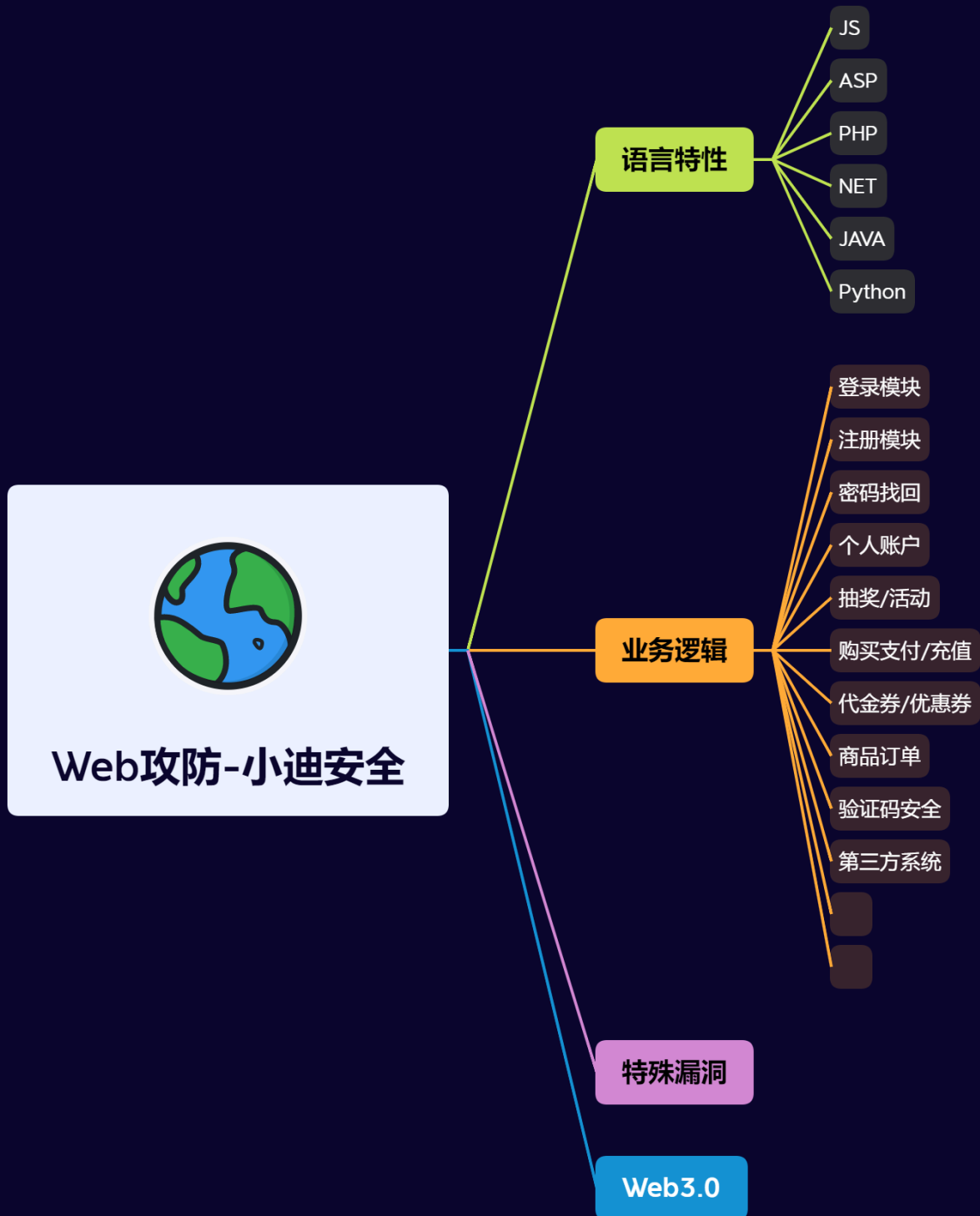


Day41 WEB攻防-ASP应用&HTTP.SYS&短文件 &文件解析&Access注入&数据库泄漏



1.知识点

- 1、ASP-SQL注入-Access数据库
- 2、ASP-默认安装-数据库泄漏下载
- 3、ASP-IIS-CVE&短文件&解析&写入

2.演示案例

2.1 ASP-默认安装-MDB数据库泄漏下载



- 1 由于大部分ASP程序与ACCESS数据库搭建，但ACCESS无需连接，都在脚本文件中定义配置好数据库路径即用，不需要额外配置安装数据库，所以大部分提前固定好的数据库路径如默认未修改，当攻击者知道数据库的完整路径，可远程下载后解密数据实现攻击。

2.2 ASP-中间件-CVE&短文件&解析&写权限



- 1 -HTTP.SYS (CVE-2015-1635)
- 2 1、漏洞描述
- 3 远程执行代码漏洞存在于 HTTP 协议堆栈 (HTTP.sys) 中，当 HTTP.sys 未正确分析经特殊设计的 HTTP 请求时会导致此漏洞。成功利用此漏洞的攻击者可以在系统帐户的上下文中执行任意代码。
- 4 2、影响版本
- 5 windows 7、windows Server 2008 R2、windows 8、windows Server 2012、windows 8.1 和 windows Server 2012 R2
- 6 3、漏洞利用条件
- 7 安装了IIS6.0以上的windows 7、windows Server 2008 R2、windows 8、windows Server 2012、windows 8.1 和 windows Server 2012 R2版本
- 8 4、漏洞复现
- 9 msfconsole
- 10 use auxiliary/dos/http/ms15_034_ulonglongadd
- 11 set rhosts xx.xx.xx.xx
- 12 set rport xx
- 13 run
- 14
- 15 -IIS短文件
- 16 1、此漏洞实际是由HTTP请求中旧DOS 8.3名称约定(SFN)的代字符(~)波浪号引起的。它允许远程攻击者在web根目录下公开文件和文件夹名称(不应该可被访问)。攻击者可以找到通常无法从外部直接访问的重要文件,并获取有关应用程序基础结构的信息。
- 17 2、漏洞成因:
- 18 为了兼容16位MS-DOS程序,windows为文件名较长的文件(和文件夹)生成了对应的windows 8.3短文件名。在windows下查看对应的短文件名,可以使用命令dir /x
- 19 3、应用场景:
- 20 后台路径获取, 数据库文件获取, 其他敏感文件获取等
- 21 4、利用工具:
- 22 <https://github.com/irsdl/IIS-ShortName-Scanner>
- 23 https://github.com/lijiejie/IIS_shortname_Scanner

```
24
25 -IIS文件解析
26 IIS 6 解析漏洞
27 1、该版本默认会将*.asp;.jpg 此种格式的文件名，当成Asp解析
28 2、该版本默认会将*.asp/目录下的所有文件当成Asp解析。
29 如: logo.asp;.jpg xx.asp/logo.jpg
30 IIS 7.x 解析漏洞
31 在一个文件路径(/xx.jpg)后面加上/xx.php会将xx.jpg/xx.php 解析为php文件
32 应用场景: 配合文件上传获取webshe11
33
34 -IIS写权限
35 IIS<=6.0 目录权限开启写入，开启webDAV，设置为允许
36 参考利用: https://cloud.tencent.com/developer/article/2050105
```

2.3 ASP-SQL注入-SQLMAP使用&ACCESS注入

```
1 ACCESS数据库无管理帐号密码，顶级架构为表名，列名（字段），数据，所以在注入猜解中一般采用字典猜解表和列再
  获取数据，猜解简单但又可能出现猜解不到的情况，由于Access数据库在当前安全发展中已很少存在，故直接使用
  SQLMAP注入，后续再说其他。
2 python sqlmap.py -u "" --tables //获取表名
3 python sqlmap.py -u "" --cloumns -T admin //获取admin表名下的列名
4 python sqlmap.py -u "" --dump -C "" -T admin //获取表名下的列名数据
```